

Security Audit Report

EMS pack v0.1.6 · Agent 1.1.5 · branch desktop+agent · docs 2026-09-20

Code review · no critical auth bypass · residual hardening listed.

Verdict

Safe for office pilot on HTTPS with strong SECRET_KEY and private repo. Payment badges no longer leak to staff/HR via UI or project list API gate field. Click-update uses host allowlist + HTTPS; cryptographic code-signing is optional next (docs/64).

ID	Sev	Finding	Status
S1	OK	bcrypt + JWT typ user/device	Keep
S2	OK	Screenshot path traversal blocked	Keep
S3	OK	Finance / partner / self-or-office gates	Keep
S4	Fixed	Advance pending visible to employees	Hidden; gate=ok for hide_money
S5	Fixed	PWA + Downloads too wide	Admin+HR only
S6	Med	JWT in localStorage (XSS)	Escape HTML; CSP later
S7	Med	No login rate limit	nginx limit_req recommended
S8	Med	12h access token	Shorten in prod if desired
S9	Ops	Updater not code-signed yet	HTTPS allowlist MVP; keys later

Sensitive data map

- Client \$ / invoices / Advance badges — Admin + Manager only.
- Partner shares — named admin partners only.
- Screenshots — office or self; audited when audit=1.
- Downloads binaries — Admin/HR distribute Agent to staff.
- Never wipe /var/lib/ems/ems.db or Agent agent_data/.